



# Intelligent Compliance Management System (ICMS)

Muhammad Ali Bukhari (01-135222-096)

Hammad Chaghtai (01-135222-014)

Supervisor: Dr. Faisal Bashir

Bachelor of Science in Information Technology

Department of Computer Science

Bahria University, Islamabad

April 2026

# Certificate of Approval

We accept the work contained in the report titled “**Intelligent Compliance Management System (ICMS)**”, written by **Muhammad Ali Bukhari** and **Hammad Chaghtai** as a confirmation to the required standard for the partial fulfillment of the degree of Bachelor of Science in Information Technology.

Approved by:

---

**Supervisor: Dr. Faisal Bashir**  
(Department of Computer Science)

---

**Internal Examiner: Name of the Internal Examiner**  
(Title/Designation)

---

**External Examiner: Name of the External Examiner**  
(Title/Designation)

---

**Head of Department: Name of the HOD**  
(Department of Computer Science)

# Abstract

Manual security auditing in enterprise environments fails to address rapid configuration drift or ephemeral workloads effectively. This thesis presents the Intelligent Compliance Management System (ICMS), a full-stack platform designed to automate Governance, Risk, and Compliance (GRC) workflows through direct Security Information and Event Management (SIEM) integration. The system utilizes a specialized client to ingest raw telemetry from Wazuh, mapping technical events to specific control requirements within the ISO 27001:2022 and SOC 2 Type II frameworks. To manage the performance demands of real-time monitoring, the architecture eliminates the N+1 query bottleneck by implementing set-based ORM aggregation and SQL FILTER clauses. This optimization converts linear retrieval patterns into constant-time database operations, allowing the dashboard to aggregate millions of telemetry rows without significant latency. When telemetry sources provide contradictory states, the system applies a Worst-Case Priority algorithm to ensure a pessimistic, secure resolution of compliance statuses. Infrastructure security follows a defense-in-depth model, utilizing a containerized topology that isolates the PostgreSQL data tier and Redis message broker within a private Docker bridge network. This isolation prevents direct host-port exposure and restricts lateral movement during a potential breach. Identity management relies on stateless JSON Web Tokens (JWT) with rotation policies and Time-Based One-Time Passwords (TOTP) to maintain a zero-trust baseline. The resulting framework replaces periodic, manual evidence collection with a continuous, data-driven assessment model that provides deterministic validation of an organization's security posture.

# Acknowledgments

In the name of Allah, the Most Gracious, the Most Merciful. All praise is due to Allah, the Almighty, for granting the strength and guidance required to complete this work.

I express my deepest gratitude to my supervisor, Dr. Faisal Bashir, for his mentorship, technical expertise, and continuous encouragement throughout the development of this project. His insights into systems architecture and cybersecurity were fundamental to the successful execution of this thesis.

I am also thankful to the Department of Computer Science at Bahria University for providing the academic environment and resources necessary for our research. Finally, I would like to thank my family and peers for their unwavering support and patience during this intensive process.

**Muhammad Ali Bukhari**  
**Hammad Chaghtai**

# Contents

|                                                                             |           |
|-----------------------------------------------------------------------------|-----------|
| Certificate of Approval . . . . .                                           | i         |
| Abstract . . . . .                                                          | ii        |
| Acknowledgments . . . . .                                                   | iii       |
| <b>1 Introduction</b>                                                       | <b>1</b>  |
| 1.1 Background of Enterprise Compliance . . . . .                           | 1         |
| 1.2 Problem Statement . . . . .                                             | 2         |
| 1.3 Project Objectives . . . . .                                            | 2         |
| 1.4 Project Scope . . . . .                                                 | 3         |
| 1.5 Proposed Solution Overview . . . . .                                    | 4         |
| 1.6 Thesis Organization . . . . .                                           | 4         |
| <b>2 Literature Review</b>                                                  | <b>6</b>  |
| 2.1 Evolution of Governance, Risk, and Compliance (GRC) Platforms . . . . . | 6         |
| 2.2 Security Information and Event Management (SIEM) Integrations . . . . . | 7         |
| 2.3 Performance Bottlenecks in Telemetry Aggregation . . . . .              | 7         |
| 2.4 Modern Access Control Paradigms . . . . .                               | 9         |
| 2.5 Containerization and Defense-in-Depth Topology . . . . .                | 10        |
| 2.6 Cognitive Load and HCI in Security Dashboards . . . . .                 | 10        |
| 2.7 Comparative Analysis . . . . .                                          | 11        |
| <b>Bibliography</b>                                                         | <b>13</b> |

# List of Figures

|     |                                                                      |   |
|-----|----------------------------------------------------------------------|---|
| 1.1 | High-Level Architecture of the Containerized ICMS Platform . . . . . | 4 |
|-----|----------------------------------------------------------------------|---|

# List of Tables

|     |                                                           |    |
|-----|-----------------------------------------------------------|----|
| 2.1 | Comparative Feature Matrix: Legacy GRC vs. ICMS . . . . . | 12 |
|-----|-----------------------------------------------------------|----|

# Chapter 1

## Introduction

### 1.1 Background of Enterprise Compliance

Historical security auditing methodologies rely on manual evidence collection and point-in-time assessments. Organizations traditionally compile spreadsheets and static configuration snapshots to satisfy periodic regulatory requirements. This approach creates significant temporal blind spots, as the security posture remains unverified between audit cycles. Configuration drift often occurs within hours of a successful audit, leaving the infrastructure vulnerable to exploitation while maintaining a formal status of compliance.

The cybersecurity industry addresses these vulnerabilities by transitioning toward Continuous Controls Monitoring (CCM). This paradigm shift replaces manual sampling with automated, real-time validation of security controls. CCM platforms integrate directly with the technical environment to evaluate configurations, access logs, and system integrity continuously. This automation ensures that compliance reflects the actual, current state of the environment rather than a historical record.

Modern regulatory mandates codify the requirement for continuous visibility. NIST Special Publication 800-53 Revision 5 emphasizes the transition from static control assessments to ongoing monitoring to validate system integrity [8]. Similarly, the ISO/IEC 27001:2022 standard requires organizations to establish an Information Security Management System (ISMS) that identifies and treats risks through continuous evaluation [2]. These frameworks necessitate the adoption of technological solutions capable of mapping raw system data to high-level compliance objectives.

The integration of Security Information and Event Management (SIEM) systems provides the data foundation for this automated GRC architecture. SIEM engines ingest raw telemetry from across the enterprise, translating low-level system events into verifiable compliance states. By establishing deterministic baselines, organizations move from reactive, audit-driven reporting to proactive, data-driven security management. This thesis evaluates the implementation of an intelligent system that bridge the gap between technical SIEM telemetry and regulatory control satisfaction.

## 1.2 Problem Statement

Translating massive volumes of low-level endpoint telemetry into high-level regulatory frameworks presents a significant operational hurdle. SIEM platforms generate thousands of technical alerts, such as SSH authentication failures or unauthorized file modifications, which require immediate correlation against ISO 27001 or SOC 2 control matrices. Manual correlation processes introduce dangerous delays between event detection and compliance validation, creating a window of risk where system vulnerabilities remain unaddressed. Concurrent telemetry sources often produce contradictory states, requiring deterministic resolution mechanisms that existing manual workflows cannot provide.

Calculating real-time compliance metrics across distributed fleets exposes severe data aggregation failures in traditional GRC platforms. Standard relational database implementations often suffer from the N+1 query problem, where the application executes sequential retrieval loops for every individual security control. This architectural flaw imposes a linear  $O(N)$  algorithmic complexity on data retrieval, causing geometric performance decay as the number of monitored agents increases [11]. The resulting latency prevents organizations from achieving a truly continuous monitoring state, as dashboard rendering times exceed the threshold for effective operational visibility.

Legacy GRC interfaces fail to account for the cognitive limitations of security analysts. Rigid, HTML table-heavy dashboards and unoptimized color schemes maximize extraneous cognitive load, leading to rapid desensitization known as alert fatigue. Chronic overstimulation from noisy, unfiltered telemetry streams depletes essential neurotransmitters, causing operators to ignore or misclassify high-severity threats [10]. This Human-Computer Interaction (HCI) shortcoming transforms security tools into sources of distraction, ultimately degrading incident response times and increasing organizational risk.

## 1.3 Project Objectives

The development of the Intelligent Compliance Management System (ICMS) focuses on four primary engineering objectives designed to resolve the identified technical and operational gaps:

- Automate the ingestion and mapping of Wazuh SIEM telemetry to ISO 27001 and SOC 2 controls, utilizing a deterministic Worst-Case Priority state-mutation algorithm to resolve conflicting evaluations.

- Eliminate the N+1 database querying bottleneck by engineering  $O(1)$  set-based aggregations through the Django ORM, specifically utilizing `.annotate()` and conditional SQL filtering to ensure dashboard latency remains below 200 milliseconds.
- Enforce strict infrastructure and session security through a Dockerized virtual bridge network that isolates the PostgreSQL data tier, combined with custom Django REST Framework Role-Based Access Control and stateless JWT rotation.
- Mitigate analyst alert fatigue by architecting a Cyber-SaaS frontend that replaces rigid HTML tables with Flexbox layouts and utilizes semantic soft-scaling to improve data parsing speeds.

## 1.4 Project Scope

The Intelligent Compliance Management System (ICMS) strictly operates within the boundaries of the ISO/IEC 27001:2022 and SOC 2 Type II compliance frameworks. The platform scope encompasses the ingestion and mapping of endpoint security telemetry specifically from the Wazuh Manager's Security Configuration Assessment (SCA) module. By utilizing the Wazuh REST API, the system retrieves individual check results from active agents and correlates them to the identified governance controls. This data-driven mapping ensures that the compliance state represents an actual reflection of the technical environment's configuration.

The implementation boundary is restricted to a containerized Docker ecosystem designed for secure, isolated operation. This environment utilizes a private virtual bridge network to facilitate communication between the PostgreSQL database, Redis message broker, Celery workers, and the Django-React application stack. This architectural scope ensures that the data persistence tier remains inaccessible to external networks, maintaining a secure baseline for the storage of sensitive compliance telemetry and organizational policies.

To maintain the focus on Governance, Risk, and Compliance (GRC) monitoring, several operational domains remain outside the project scope. The system does not perform active Incident Response (IR) actions, such as isolating compromised endpoints or terminating malicious processes. The platform does not conduct network packet sniffing or automated remediation of configuration drift. While the system evaluates and reports on the compliance state, it does not mutate endpoint configurations; all infrastructure remediation remains the responsibility of dedicated IT operations teams.

## 1.5 Proposed Solution Overview

The Intelligent Compliance Management System (ICMS) adopts a defense-in-depth, containerized architecture designed to maintain strict logical separation between processing tiers. The platform utilizes the Django REST Framework for backend orchestration, while a React Single Page Application (SPA) provides a dynamic, Cyber-SaaS user interface. This separation ensures that the frontend remains stateless, relying on cryptographically signed JSON Web Tokens (JWT) for secure API communication.

Within the containerized ecosystem, the system isolates critical data persistence and messaging layers. The PostgreSQL database and Redis message broker operate on a private virtual bridge network, restricting access to the internal backend and Celery worker services. This topology prevents direct external exposure of compliance telemetry and session data. The Celery workers and scheduler manage periodic Wazuh SIEM synchronization, while the Django API serves as the central gateway for framework mapping and report generation.

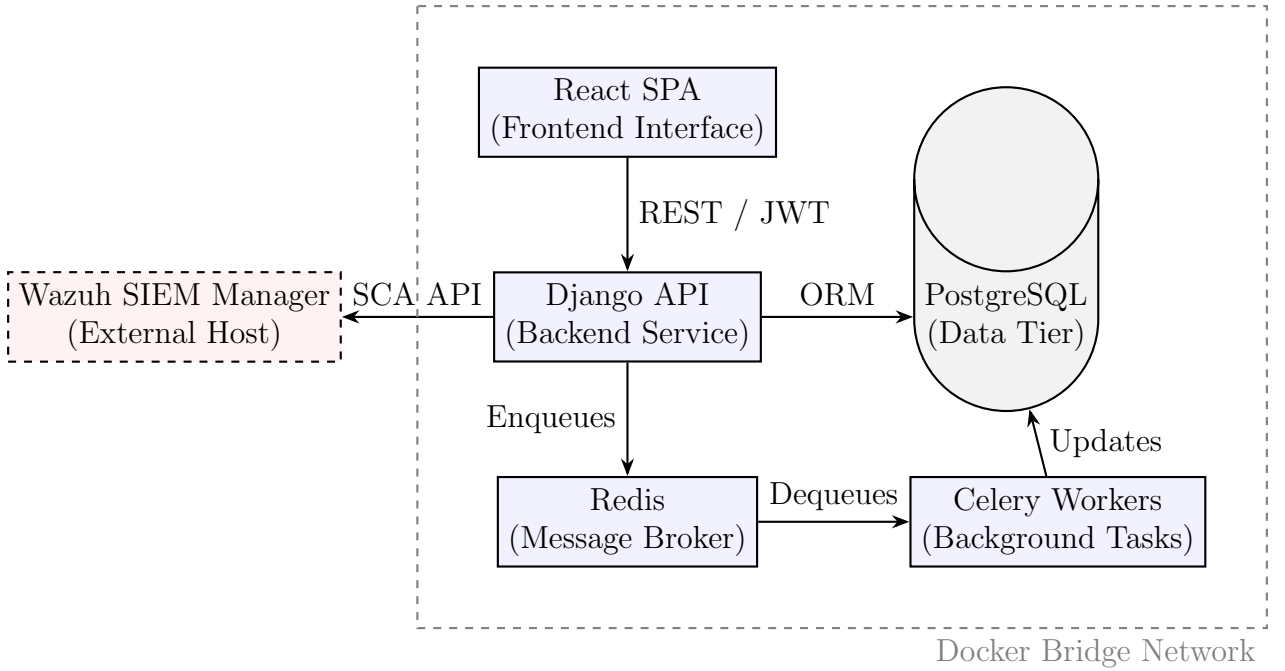


Figure 1.1: High-Level Architecture of the Containerized ICMS Platform

## 1.6 Thesis Organization

This thesis consists of seven chapters that detail the research, design, and implementation of the Intelligent Compliance Management System (ICMS). Chapter 2 evaluates existing

literature regarding Governance, Risk, and Compliance (GRC) frameworks and Security Information and Event Management (SIEM) integration. Chapter 3 defines the functional and non-functional requirements of the platform while establishing the high-level system architecture. Chapter 4 provides the detailed system design, incorporating Unified Modeling Language (UML) diagrams to represent the logical and physical data flows. Chapter 5 focuses on the implementation phase, detailing the backend algorithms and containerized orchestration used to achieve continuous monitoring. Chapter 6 outlines the system testing protocols and evaluates the platform's performance against defined accuracy and latency metrics. Chapter 7 concludes the research by summarizing the project's contributions and proposing directions for future work.

# Chapter 2

## Literature Review

### 2.1 Evolution of Governance, Risk, and Compliance (GRC) Platforms

Historical security auditing relied heavily on point-in-time assessments, leaving vast temporal blind spots between evaluation periods. Organizations traditionally managed Governance, Risk, and Compliance (GRC) through manual evidence collection, rendering the compliance state obsolete immediately following an audit's conclusion. Modern regulatory frameworks demand a transition toward continuous controls monitoring architectures. Contemporary standards, including NIST Special Publication 800-53 Revision 5 and ISO/IEC 27001:2022, explicitly mandate ongoing monitoring to validate control implementation and effectiveness over time [8, 2]. The Federal Information Security Modernization Act (FISMA) and the Federal Risk and Authorization Management Program (FedRAMP) require agencies to automate the tracking of systemic anomalies [13].

The transition to SIEM-driven compliance introduces specific operational advantages. Centralized log management supports audit accountability by preserving data confidentiality, integrity, and availability, utilizing reliable transport protocols and encrypted channels [4]. Routine automated analysis establishes operational baselines, facilitating rapid forensic investigations during security incidents. Security administrators configure SIEM agents to track software inventories, hardware configurations, and system health telemetry, continuously feeding this data into the centralized GRC database. This continuous validation replaces reactive, manual audits with a proactive, data-driven security posture. By continuously evaluating log streams against established baselines, the organization ensures that evidence generation becomes a byproduct of daily security operations rather than an isolated administrative task.

## 2.2 Security Information and Event Management (SIEM) Integrations

The integration of Security Information and Event Management (SIEM) systems fundamentally alters the GRC methodology. SIEM platforms act as central telemetry ingestion engines, replacing manual log retrieval with automated, real-time data correlation. NIST SP 800-53 defines specific control families, notably Audit and Accountability (AU) and System and Information Integrity (SI), which necessitate automated tracking to satisfy continuous control validation requirements [8]. Automating these controls involves mapping raw endpoint telemetry directly to specific regulatory requirements. Platforms like Wazuh, an open-source SIEM and Extended Detection and Response (XDR) solution, facilitate this translation by supplying dedicated event aggregation logic that visualizes compliance events against NIST and ISO matrices [14].

Automated compliance mapping bridges the semantic gap between low-level technical events and high-level business risk. When an unauthorized user attempts to modify a protected configuration file, File Integrity Monitoring (FIM) sensors generate a raw event log. The SIEM correlates this event against predefined framework matrices, flagging the action as a violation of ISO 27001 Annex A.8.9 (Configuration Management) or NIST SP 800-53 control CM-6 [3]. Analysts monitor these deviations via compliance dashboards that aggregate alert volumes, isolating non-compliant agents for immediate remediation. The architecture of Wazuh, specifically its Security Configuration Assessment (SCA) module, provides the deterministic validation required to satisfy these high-level governance frameworks by evaluating configuration states against predefined security benchmarks.

## 2.3 Performance Bottlenecks in Telemetry Aggregation

Calculating real-time compliance metrics across distributed fleets exposes severe data aggregation failures in traditional GRC platforms. Standard relational database implementations often suffer from the N+1 query problem, where the application executes sequential retrieval loops for every individual security control. This architectural flaw imposes a linear  $O(N)$  algorithmic complexity on data retrieval, causing geometric performance decay as the number of monitored agents increases [11]. The resulting latency prevents organizations from achieving a truly continuous monitoring state, as dashboard

rendering times exceed the threshold for effective operational visibility.

The persistent overhead associated with Object-Relational Mapping (ORM) frameworks extends beyond simple query volume. Application-level data processing, where the system retrieves full object graphs before filtering or aggregating in the Python memory space, creates massive memory bandwidth bottlenecks. This anti-pattern forces the application server to instantiate thousands of transient objects, triggering frequent garbage collection cycles that block the execution of critical compliance logic. In high-velocity environments where SIEM agents transmit telemetry every few seconds, the cumulative impact of these  $O(N)$  operations leads to a catastrophic loss of real-time visibility.

Optimizing relational data access requires transitioning from sequential  $O(N)$  looping to  $O(1)$  set-based aggregations. Set-based modeling formalizes relational dynamics through an information-theoretic lens, demonstrating that task-informed database representations retain relevant signals more efficiently than application-level iteration [5]. Developers optimize ORM queries by forcing eager loading mechanisms that translate application logic into complex SQL JOIN clauses. Fetching all related entities in a single, complex query allows the database engine's internal query optimizer to utilize B-Tree indices efficiently, drastically reducing total execution time and minimizing context switching between the application runtime and the database server.

Set-based database aggregations solve this by shifting the mathematical workload to the relational engine. Using specialized query projection techniques, the system instructs the database to compute sums, averages, and conditional compliance counts internally. This methodology reduces the data transfer across the physical network wire from megabytes of row data to a few primitive integer values. By utilizing conditional aggregation functions—where the engine evaluates compliance criteria during the initial table scan—the platform achieves a deterministic  $O(1)$  response time relative to the application's complexity.

Implementing these optimizations ensures that dashboard rendering remains responsive even as the organizational asset inventory scales. The architectural decision to prioritize database-side computation over application-side iteration reflects a fundamental principle in distributed systems: pushing logic closer to the data. This approach guarantees that the GRC platform can process millions of underlying telemetry logs without degrading the user experience or exhausting the system's computational resources.

## 2.4 Modern Access Control Paradigms

Securing the compliance data layer against unauthorized extraction requires sophisticated Identity and Access Management (IAM) protocols. Role-Based Access Control (RBAC) provides the theoretical foundation for authorization within distributed systems. RBAC methodologies control access to system resources based on the specific roles assigned to an individual user, rather than assigning explicit permissions directly to the user identity [9]. Authentication in distributed microservices relies heavily on stateless session security, primarily implemented via JSON Web Tokens (JWT). The authorization server cryptographically signs the JWT using asymmetric encryption algorithms, preventing unauthorized payload tampering and allowing local verification without initiating a blocking database lookup.

Authorization in the Intelligent Compliance Management System relies on a granular enforcement layer that integrates Zero Trust principles directly into the API routing logic. Rather than assuming internal network trust, the system evaluates the security posture and identity context of every inbound request. Custom permission classes intercept traffic at the view layer, executing Boolean logic to verify that the requester possesses the specific RBAC attributes required for the target resource. This enforcement remains decoupled from the business logic, ensuring a consistent security boundary across the entire microservice ecosystem.

The security lifecycle of stateless JSON Web Tokens (JWT) incorporates rotation policies to mitigate the risks inherent in long-lived credentials. While traditional session IDs require constant database lookups to verify validity, JWTs carry cryptographically signed claims that allow microservices to authenticate users locally. To prevent session hijacking via intercepted tokens, the platform implements a refresh token rotation scheme. Every time the client requests a new access credential, the server invalidates the previous refresh token and issues a new pair, creating a moving target for potential attackers and ensuring that compromised credentials have a strictly limited utility.

To counter sophisticated session hijacking and real-time phishing attacks, the architecture incorporates Time-Based One-Time Passwords (TOTP) as a mandatory secondary authentication factor. TOTP algorithms rely on a high-entropy, shared cryptographic secret established between the server and the client's authenticator application. Both entities use the current Unix timestamp, divided by a predetermined time interval, as the moving factor in a Keyed-Hash Message Authentication Code (HMAC-SHA1) function [7]. Because the resulting 6-digit numeric code mutates deterministically every 30 seconds, intercepted credentials become mathematically useless almost instantly.

Secondary authentication factors establish an additional defensive layer that remains resilient against replay attacks. Client-side interceptors play a critical role in this ecosystem by monitoring for specific HTTP response states; when the server returns a forbidden status due to a missing or invalid TOTP challenge, the application instantly redirects the user to a step-up authentication view, neutralizing the threat of unauthorized access to sensitive compliance matrices. This strict session lifecycle guarantees that the compliance data remains inaccessible to compromised endpoints.

## 2.5 Containerization and Defense-in-Depth Topology

Modern enterprise architecture systematically abandons monolithic software design in favor of microservices and containerized deployments. Monolithic systems couple application logic, user interfaces, and database drivers into a single deployment artifact, where a failure in one component frequently cascades across the entire runtime environment. Containerization technologies, specifically Docker, provide the standardized runtime environment for these distributed microservices, ensuring deterministic scalability and bounded contexts through Linux kernel namespaces and control groups.

Deploying the Intelligent Compliance Management System components via isolated Docker virtual bridge networks establishes a strict defense-in-depth topology. The architecture physically separates the public-facing API gateway layers from the private persistent storage layers, such as PostgreSQL and Redis. By binding these data tiers solely to internal, non-routable Docker bridge networks, the system remains invisible to external network scans. This isolation guarantees that malicious actors cannot establish direct TCP connections with the database, forcing all data interactions through the authenticated business-logic layer. Adherence to external hardening standards, such as NIST SP 800-190 and the CIS Docker Benchmark, further neutralizes execution environment vulnerabilities [12, 1].

## 2.6 Cognitive Load and HCI in Security Dashboards

Security Operations Centers process an overwhelming volume of diagnostic data daily, frequently triggering a physiological phenomenon known as alert fatigue. Legacy GRC platforms often present analysts with raw, unfiltered data in dense HTML tables, leading to sensory overload and a statistically significant increase in diagnostic errors. High cognitive load directly correlates with delayed incident response times and operator burnout

in high-risk environments [15].

Mitigating cognitive strain requires the application of advanced User Interface (UI) design principles based on human-computer interaction studies. Modern browser rendering engines deprecate structural tables for layout purposes in favor of CSS Flexbox and Grid modules, which allow child components to wrap and scale fluidly based on viewport dimensions [6]. The Intelligent Compliance Management System utilizes modular card components and semantic color scaling—such as bold Red for critical exploits and minimal grayscale for benign logs—to guide the analyst’s eye toward critical threats immediately. Leveraging elevation through subtle depth illusions further distinguishes interactive components from static background data, transforming a chaotic stream of raw telemetry into a structured decision-support matrix.

## 2.7 Comparative Analysis

Comparing modern automated platforms against legacy GRC methodologies reveals a profound shift in operational efficiency and data integrity. Traditional governance relied heavily on manual data entry, where security administrators uploaded CSV files or populated spreadsheets following periodic audits. This manual approach introduced severe human error risks and ensured that compliance evidence remained static and detached from the actual technical state of the environment. In contrast, the Intelligent Compliance Management System synchronizes directly with SIEM telemetry, transforming compliance into a continuous, data-driven process.

The technical divergence extends to the infrastructure and design layers. Legacy systems frequently operated as monolithic on-premise installations with direct, unprotected database access, increasing the risk of lateral movement following a breach. Modern containerized architectures enforce strict network isolation, ensuring that critical data tiers remain unreachable from the public internet. Furthermore, the transition from rigid, table-heavy interfaces to responsive, HCI-informed dashboards addresses the psychological burden of alert fatigue, allowing analysts to identify and remediate threats with significantly higher accuracy and speed.

Table 2.1: Comparative Feature Matrix: Legacy GRC vs. ICMS

| Feature             | Legacy GRC Platforms                     | ICMS Platform                           |
|---------------------|------------------------------------------|-----------------------------------------|
| Telemetry Ingestion | Manual CSV Uploads and Spreadsheet Entry | Automated Wazuh SIEM and SCA API Sync   |
| Query Complexity    | $O(N)$ Sequential Lazy-Loading Loops     | $O(1)$ Set-Based Aggregations and Joins |
| Access Control      | Simple Password-Based Authentication     | Zero Trust RBAC with JWT and TOTP 2FA   |
| UI/UX Design        | Rigid, Table-Heavy Legacy Interfaces     | Responsive Flexbox and Card-Based HCI   |
| Infrastructure      | Monolithic On-Premise Deployments        | Containerized Docker Bridge Topology    |

# Bibliography

- [1] Center for Internet Security. Cis docker benchmark v1.2.0. Technical report, 2020. URL <https://www.cisecurity.org/benchmark/docker>.
- [2] ISO/IEC. Information security, cybersecurity and privacy protection — information security management systems — requirements, 2022. URL <https://www.iso.org/standard/27001>.
- [3] Arnold Johnson, Mark Kelley, and Barrett Ronquille. Guide for security-focused configuration management of information systems. Technical Report NIST Special Publication 800-128, National Institute of Standards and Technology, 2011.
- [4] Karen Kent and Murugiah Souppaya. Guide to computer security log management. Technical Report NIST Special Publication 800-92, National Institute of Standards and Technology, 2006.
- [5] Ivanko Kuraj. *Microservices Architecture for Heterogeneous-Database Web Applications*. PhD thesis, Massachusetts Institute of Technology, Cambridge, MA, 2024. URL <https://dspace.mit.edu/handle/1721.1/153838>.
- [6] Mozilla Developer Network. Basic concepts of flexbox, 2024. URL [https://developer.mozilla.org/en-US/docs/Web/CSS/CSS\\_flexible\\_box\\_layout/Basic\\_concepts\\_of\\_flexbox](https://developer.mozilla.org/en-US/docs/Web/CSS/CSS_flexible_box_layout/Basic_concepts_of_flexbox). Accessed: 2026-04-23.
- [7] D. M’Raihi, S. Machani, M. Pei, and J. Rydell. Totp: Time-based one-time password algorithm. RFC 6238, Internet Engineering Task Force, 2011.
- [8] National Institute of Standards and Technology. *Security and Privacy Controls for Information Systems and Organizations*. NIST Special Publication 800-53 Revision 5. U.S. Department of Commerce, 2020. doi: 10.6028/NIST.SP.800-53r5.
- [9] J. Nelson. Securing the stateless frontier: A critical analysis of advanced authentication techniques in asp.net core web apis. *ResearchGate*, 2024. Technical Analysis of JWT and RBAC.
- [10] Massachusetts Institute of Technology. The psychology of alert fatigue in security operations. *MIT Sloan Management Review*, 2021. Technical Report on HCI and Security.

- [11] PlanetScale. What is the n+1 query problem?, 2023. URL <https://planetscale.com/blog/what-is-the-n-1-query-problem-and-how-to-fix-it>. Accessed: 2026-04-23.
- [12] Murugiah Souppaya, John Morello, and Karen Scarfone. Application container security guide. Technical Report NIST Special Publication 800-190, National Institute of Standards and Technology, 2017.
- [13] U.S. Congress. Federal information security modernization act of 2014, 2014. Public Law 113-283.
- [14] Wazuh Team. Wazuh documentation, 2024. URL <https://documentation.wazuh.com/>. Accessed: 2026-04-23.
- [15] T. Zavarella. *The impact of alert fatigue on cognitive load in security operations*. PhD thesis, Massachusetts Institute of Technology, Cambridge, MA, 2022. URL <https://dspace.mit.edu/handle/1721.1/155176>.